Webserver Rust 安全门户

使用、配置、部署与更新指南

版本：2026-09-19 | 默认监听：0.0.0.0:9100 | 运行方式：非 Docker 或 Docker

> 这份指南面向门户管理员和部署人员，覆盖首次启动、Account Hub 登录、订阅管理、组织成员、漏洞审核、邮件与增强报告配置，以及远端更新流程。请把真实密码、API 密钥和 MongoDB 连接串放在 .env 或服务器密钥管理中，不要写入 Git。

你将学会

- 从源码启动一个隔离的本地实例。
- 配置 MongoDB、Account Hub、SMTP、Tavily 和 LLM。
- 使用订阅、组织成员、审核和报告页面。
- 在远端服务器上安全地构建、重启和验证非 Docker 服务。

目录

章节	内容
1	快速开始
2	登录、角色和页面
3	配置文件与环境变量
4	订阅、收件邮箱与邮件
5	漏洞审核与报告
6	部署与更新
7	故障排查与检查清单

1. 快速开始

项目目录是 webserver-rust。Rust 服务直接读取该目录中的 templates、static 和 config；运行时不需要旁边的旧 Python 项目。

首次安装需要 Rust、MongoDB 和一个可写的工作目录。Dockerfile 使用 Rust 1.91 作为构建环境，生产环境也可以直接使用已编译的 target/release/webserver-rust。

本地启动步骤

在项目目录执行

```
cd /path/to/webserver-rust
cp .env.example .env
# Edit .env and set the Mongo URI, session secret, and bootstrap password
cargo fmt -- --check
cargo test
cargo build --release
./target/release/webserver-rust
```

打开 http://127.0.0.1:9100/login。启用 Account Hub 时，浏览器仍访问门户的 /login；Account Hub 的完整接口地址只写在 ACCOUNT_HUB_LOGIN_URL 和 ACCOUNT_HUB_TOKEN_CHECK_URL。

本地管理员使用 /login/local。该入口用于断网或 Account Hub 故障时的 break-glass 管理，不应当作为普通用户的登录入口。

> 服务启动时会创建或修复配置中的本地 bootstrap 管理员。生产环境请首次登录后立即使用强密码，并限制服务器和 MongoDB 的网络访问。

常用开发检查

```
cargo fmt -- --check
cargo test
cargo build --release
node --check static/js/reviews/index.js
node --check static/js/subscriptions/index.js
git diff --check
```

2. 登录、角色和页面

Account Hub 登录

启用 Account Hub 后，门户负责显示 /login、接收表单并向 Account Hub 验证。成功登录时，门户会保存最近一次 token-check 返回的用户名、邮箱、组织、组织 ID、系统角色和组织管理员标记。

Account Hub 示例

```
ACCOUNT_HUB_ENABLED=true
ACCOUNT_HUB_LOGIN_URL=https://account-hub.example/accounthub-api-gateway/auth/user/oauth/login
ACCOUNT_HUB_TOKEN_CHECK_URL=https://account-hub.example/accounthub-api-gateway/user/open-api/v1/user/view/info
ACCOUNT_HUB_REQUIRED_ROLE=CVE-SYSTEM
```

角色规则

- 用户必须拥有 ACCOUNT_HUB_REQUIRED_ROLE 对应的系统角色，默认是 CVE-SYSTEM。
- 匹配 -admin（例如 CVE-SYSTEM-admin）的用户是组织管理员。
- 组织管理员只能管理同一组织的成员和自己创建的本地订阅。
- 本地 bootstrap 管理员通过本地登录管理系统，权限不依赖 Account Hub。

页面导航

地址	用途	主要使用者
/login	Account Hub 登录页面；成功后回到门户	Account Hub 用户
/login/local	本地管理员登录	本地管理员
/subscriptions	我的订阅或订阅管理；组织管理员看到组织面板	全部已登录用户
/organization/members	查看和维护 Account Hub 组织成员资料	组织管理员
/settings	查看账户、组织和角色；本地用户可维护资料	全部已登录用户
/reviews	筛选漏洞审核记录、选择、导出和生成报告	管理员
/reports	查看报告任务、下载、翻译、取消和删除	管理员
/operations	检查健康状态、模板和运维缓存	管理员

> Account Hub 邮箱是订阅收件邮箱的唯一来源。用户下一次成功登录时会同步新邮箱，并把现有订阅的收件人更新为单一的新邮箱。

3. 配置文件与环境变量

配置优先级

启动时先读取项目根目录的 .env，再读取 APP_CONFIG 指向的 JSON；同一个设置如果同时存在，非空环境变量优先。config/config.json 适合保存不敏感的默认值，.env 适合保存密码、密钥、连接串和部署差异。

必填和基础设置

变量	作用	示例或默认值
LOCAL_MONGO_URI / MONGO_URI	MongoDB 连接；MONGO_URI 优先	mongodb://localhost:27017/
FLASK_SECRET_KEY	签名登录会话的密钥	使用随机长字符串
WEB_AUTH_BOOTSTRAP_USERNAME	本地 bootstrap 管理员用户名	admin
WEB_AUTH_BOOTSTRAP_PASSWORD	本地 bootstrap 管理员密码	不要使用示例值
PORT	HTTP 监听端口	9100
WEBSERVER_ROOT	templates、static、config 所在目录	默认 Cargo 项目目录
APP_CONFIG	替代 JSON 配置路径	config/config.json

MongoDB 数据库

当前 Rust 运行时实际使用 WEB_DATABASE 和 VULNERABILITIES_DATABASE。前者保存认证、订阅、报告任务等门户数据，后者保存漏洞数据和以 _review 结尾的审核视图。config/config.json 中的 mongodb.local_database 是旧配置兼容项，不能替代这两个运行时设置。两个数据库指向 web 时，门户数据和漏洞数据会共用同一个数据库，但集合仍然不同；生产环境通常建议分开。

数据库示例

```
WEB_DATABASE=web
VULNERABILITIES_DATABASE=vulnerabilities
# Production may use separate databases:
# WEB_DATABASE=portal_prod
# VULNERABILITIES_DATABASE=vulnerability_prod
```

Account Hub、邮件和外部服务

变量	说明
ACCOUNT_HUB_ENABLED	true 才显示并启用 Account Hub 登录
ACCOUNT_HUB_LOGIN_URL	完整的 Account Hub 登录 API URL
ACCOUNT_HUB_TOKEN_CHECK_URL	完整的用户信息或 token-check API URL
ACCOUNT_HUB_REQUIRED_ROLE	门户要求的 system role，默认 CVE-SYSTEM
ACCOUNT_HUB_TIMEOUT_SECONDS	Account Hub 请求超时，默认 5 秒
SMTP_HOST / SMTP_PORT	邮件服务器，端口默认 587
SMTP_USERNAME / SMTP_PASSWORD / SMTP_FROM	SMTP 账号、密码和发件地址
SMTP_USE_TLS / SMTP_USE_SSL	传输安全方式；不要同时启用两者
TAVILY_API_KEY(S)	增强报告的外部搜索；支持单个或 JSON 数组密钥
RUST_SCHEDULER_ENABLED	true 才启动定时通讯和报告任务
ENRICHED_LLM_BASE_URL / MODEL	增强报告的 OpenAI 兼容 LLM 地址和模型

4. 订阅、收件邮箱与邮件

普通 Account Hub 用户

- 在 /subscriptions 创建或编辑自己的订阅。收件邮箱从最近一次 Account Hub 登录同步，表单只读。
- 后端会拒绝伪造邮箱、多个收件人或其他用户的邮箱。
- 在 /settings 可以查看账户和组织；Account Hub 用户的资料邮箱编辑区已隐藏。

组织管理员

- 成员行的添加和编辑使用该成员最近一次成功登录同步的 Account Hub 邮箱。
- 页面顶部“添加订阅”创建本地订阅：用户名和一个或多个手工邮箱可编辑，组织固定为管理员组织。
- 本地订阅可再次编辑，也可由创建它的组织管理员删除；Account Hub 成员订阅不显示删除按钮。

本地管理员

- 本地订阅可以手工填写多个收件人，继续使用现有的密码和本地账号规则。
- 邮件发送方式统一为分别发送给每个收件人，避免收件人互相看到地址。

订阅保存前的建议

- 先确认 SMTP 服务器、发件人和 TLS 设置，再启用 newsletter 或 weekly report。
- 使用报告预览确认筛选条件，尤其是时间范围、严重程度和 vendor/product 清单。

> 如果订阅已经保存但提示通知邮件发送失败，订阅状态可能已经写入 MongoDB。先检查 SMTP 配置和远端日志，再决定是否重新保存，避免重复创建。

邮件配置示例

```
SMTP_HOST=smtp.example.com
SMTP_PORT=587
SMTP_USERNAME=portal@example.com
SMTP_PASSWORD=<smtp-password>
SMTP_FROM=portal@example.com
SMTP_USE_TLS=true
SMTP_USE_SSL=false
```

5. 漏洞审核与报告

漏洞审核页面 /reviews

- 按 CVE、标题、受影响产品和严重程度搜索。
- 抓取时间支持全部时间、今天、最近 7 天和自定义范围；自定义输入按香港时间解释。
- 勾选记录后可以导出 JSON，或把选择交给报告页面。
- 审核视图名称通常以 REVIEW_VIEW_SUFFIX 结尾，默认是 _review。

报告页面 /reports

- 查看报告任务的排队、运行、完成、失败和取消状态。
- 固定模板报告不需要 Tavily 或 LLM；增强周报需要 Tavily API key 和可访问的 OpenAI 兼容 LLM。
- LLM 基础地址应填写到 /v1，例如 http://100.111.82.11:8080/v1；应用会追加 /chat/completions。

增强报告配置

```
# .env overrides config/config.json
ENRICHED_LLM_BASE_URL=http://100.111.82.11:8080/v1
ENRICHED_LLM_MODEL=qwen3-8b-ipex
TAVILY_API_KEY=<tavily-api-key>
```

如果 LLM 服务只允许服务器内网访问，请把 URL 配在运行 Rust 服务的服务器上可达的地址。浏览器不需要直接访问 LLM。

运维页面 /operations

- 检查 MongoDB、调度器和近期邮件或报告状态。
- 编辑或预览新闻邮件模板。
- 增强报告的搜索和证据缓存可以在需要时清理；清理后下一次任务会重新请求外部服务。

6. 非 Docker 部署与更新

下面流程适用于当前服务器 root@100.80.2.110:/root/WEBSEVER。远端 .env 和 config/config.json 是服务器专属配置，更新源码时必须保留。

提交前

```
cd /path/to/webserver-rust
git status
git add <changed-files>
git commit -m "Describe the change"
cargo fmt -- --check
cargo test
cargo build --release
```

同步源码并保留远端配置

```
rsync -az \
  --exclude='.env' \
  --exclude='config/config.json' \
  --exclude='target/' \
  --exclude='.git/' \
  --exclude='APIs.md' \
  ./ root@100.80.2.110:/root/WEBSEVER/
```

远端检查和构建

```
ssh root@100.80.2.110 \
  'cd /root/WEBSEVER && \
   cargo fmt -- --check && \
   cargo test && \
   cargo build --release'
```

重启非 Docker 服务

```
ssh root@100.80.2.110 \
  'cd /root/WEBSEVER && \
   pids=$(pgrep -x webserver-rust || true); \
   if [ -n "$pids" ]; then kill -TERM $pids; fi; \
   sleep 2; \
   nohup ./target/release/webserver-rust \
     > webserver.log 2>&1 < /dev/null & \
   sleep 2; \
   ss -ltnp | grep ":9100"'
```

部署后验证

```
ssh root@100.80.2.110 \
  'curl -fsS -o /dev/null -w "login:%{http_code}\n" \
   http://127.0.0.1:9100/login; \
   tail -40 /root/WEBSEVER/webserver.log'
```

> 更新前先备份远端 .env 和 config/config.json。不要用 rsync --delete 盲目覆盖生产目录；保留静态资源、配置和日志的边界。

7. Docker 运行方式

项目提供 Dockerfile 和 docker-compose.example.yml。Docker 构建会在镜像中编译 Rust，并将 templates、static 和 config 复制到 /app。

```
cp .env.example .env
# Adjust LOCAL_MONGO_URI for the Docker network
docker compose -f docker-compose.example.yml up -d --build
docker compose -f docker-compose.example.yml ps
curl -I http://127.0.0.1:9100/login
```

Docker 配置提示

- 示例 compose 使用 host.docker.internal 访问宿主机 MongoDB。Linux 环境需要确认该主机名和 MongoDB 监听设置。

- 生产环境建议使用显式的 compose override 或编排平台，不要把真实 .env 提交到仓库。

- 非 Docker 服务器只运行 target/release/webserver-rust；不要同时启动容器和非容器进程占用 9100。

更新和回滚

```
# Check the current version and working tree before updating
git log -1 --oneline
git status

# Roll back to a known-good commit and rebuild
git checkout <known-good-commit>
cargo test
cargo build --release
# Then repeat the rsync, restart, and verification steps above
```

8. 故障排查与上线检查

现象	检查和处理
/login 无法渲染或模板报错	确认远端已同步 templates/static，重新 cargo build --release 并重启；查看 webserver.log。
Account Hub 登录失败	检查 ACCOUNT_HUB_LOGIN_URL 和 TOKEN_CHECK_URL 是否是完整 API URL，检查服务器是否能访问 Account Hub。
用户登录成功但邮箱显示未提供	让该用户退出并重新登录；门户只使用最近一次 token-check 的 data.email。
/reviews 提示无法查询漏洞数据库	检查 VULNERABILITIES_DATABASE、MongoDB 权限和以 _review 结尾的视图。
时间范围报 Invalid time window	使用页面的全部时间、今天、最近 7 天或合法的自定义开始和结束时间；后端兼容 daily/week。
订阅保存但邮件失败	检查 SMTP_HOST、端口、TLS/SSL 组合、凭据和发件地址；查看日志后再重试。
增强报告失败	检查 TAVILY_API_KEY、ENRICHED_LLM_BASE_URL、模型名和服务器到外部服务的网络。
端口 9100 被占用	使用 ss -ltnp 或 pgrep -af webserver-rust 找到旧进程，只停止确认过的服务进程。
服务启动后立即退出	运行 ./target/release/webserver-rust 前台启动，读取完整错误；常见原因是 Mongo URI 或 FLASK_SECRET_KEY 缺失。

上线前检查清单

- .env、config/config.json 和 MongoDB 备份已确认，且未进入 Git。
- cargo fmt -- --check、cargo test、cargo build --release 均通过。
- 远端服务只运行一个 webserver-rust 进程，并监听 0.0.0.0:9100。
- 本地管理员、Account Hub 用户和组织管理员各完成一次登录验证。
- 订阅页面的 Account Hub 邮箱只读，本地订阅可按预期编辑收件人。
- /reviews 的全部时间、今天、最近 7 天和自定义范围都能返回结果或清晰的校验错误。
- SMTP 测试邮件、报告预览和必要的调度器状态均已确认。

> 如需切换环境，优先复制 .env 和 config/config.json 为新的部署配置，再用不同 PORT、WEB_DATABASE 和 VULNERABILITIES_DATABASE 做隔离验证。确认登录、订阅、审核和邮件流程后再切换生产进程。

文档说明

本指南根据当前 webserver-rust 源码、.env.example、config/config.json、README.md 和现有部署流程整理。示例中的域名、密码、密钥和主机名均为占位符；生产部署请以服务器实际配置为准。